Title:- Replace and modernize legacy VPN Architectures With a cloud-native Zscaler Zero Trust solution To reduce attack surface and lateral movement.

Group Details

Team ID:SWTID-2026-8931

Team Leader: Niyash Ahamed A

Team member: Navaneethakridshnan J

Team member: Mohan Raj M

Team member: Durga Devi R

College Name: Pollachi College of Arts and Science, Poosaripatti

CONTACT:

Team Leader: NIYASH AHAMED A

Email id: nmcsniyashahamed@gmail.con

Team Member: NAVANEETHAKRISHNAN J

Email id: navaneethakrishnanjakkan@gmail.com

Team Member: MOHAN RAJ M

Email id: 23nmcsmohanraj@gmail.com

Team Member: DURGA DEVI R

Email id: 23nmcsdurgadevi@gmail.com

Project Details

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

This project focuses on replacing traditional VPN architectures with a modern cloud-native Zero Trust security solution using Zscaler. Many organizations still depend on legacy VPN systems to provide remote access to employees. However, traditional VPNs allow users to access the internal network once they are authenticated, which increases the risk of cyber attacks and unauthorized access.

The proposed system introduces a Zero Trust Network Access (ZTNA) model where every user and device must be verified before accessing any application. Instead of providing full network access, the system allows users to connect only to specific applications that they are authorized to use.

The Zscaler cloud platform acts as a secure gateway between users and applications. It continuously checks user identity, device security, and access policies before allowing any connection. This approach prevents attackers from moving laterally within the network and reduces the chances of data breaches.

By replacing legacy VPN infrastructure with Zscaler's cloud-native architecture, organizations can achieve better security, improved visibility, and more controlled access to applications. This modern approach helps protect sensitive data while ensuring safe and efficient remote access for users.

Intro: In modern organizations, secure remote access to applications and networks has become very important. Many companies still use traditional Virtual Private Network (VPN) architectures to allow employees to access internal resources from outside the organization. However, legacy VPN systems provide broad network access once a user is authenticated, which increases the risk of cyber attacks and unauthorized access.

To overcome these security issues, organizations are adopting the Zero Trust security model. Zero Trust is based on the principle of “Never Trust, Always Verify,” where every user and device must be continuously verified before accessing any application or resource.

This project focuses on replacing legacy VPN architectures with a cloud-native Zscaler Zero Trust solution. By implementing this approach, organizations can provide secure access to applications without exposing the internal network, thereby reducing cyber attacks and preventing lateral movement within the network.

Abstract:- Traditional VPN architectures are widely used in organizations to provide remote access to internal networks. However, these legacy systems often allow users to access the entire network after authentication, which increases the risk of cyber attacks and unauthorized access. Attackers can exploit this access to move laterally within the network and compromise sensitive data.

This project proposes a modern solution by replacing legacy VPN architectures with a cloud-native Zscaler Zero Trust security model. The Zero Trust approach ensures that every user, device, and connection is verified before granting access to any application.

By using the Zscaler platform, organizations can provide secure and controlled access to applications without exposing the internal network. This helps in reducing security risks, preventing lateral movement, and improving overall network protection.

Overall, this project demonstrates how implementing a cloud-native Zero Trust solution can enhance security, improve access control, and provide a safer alternative to traditional VPN systems

Use case scenario

1. Secure Remote Employee Access

Employees working from home can securely access company applications through the Zscaler Zero Trust platform. Instead of connecting to the entire internal network through VPN, users are verified and given access only to the specific applications they need.

2. Third-Party Vendor Access

Organizations often allow vendors or partners to access certain systems. With Zero Trust, vendors are given limited and controlled access only to the required applications, preventing them from accessing other internal resour

3. Protection Against Lateral Movement

If an attacker gains access to a user account, Zero Trust architecture prevents them from moving across the network. The system continuously verifies access and restricts the attacker from reaching other applications or data.

4. Secure Access for Cloud Applications

Employees can safely access cloud-based applications through Zscaler without exposing the internal network. The platform inspects and controls traffic before allowing users to connect to the application.

5. Device Security Verification

Before granting access, the system checks whether the user's device is secure and compliant with security policies. If the device is unsafe or infected, access will be restricted to protect the network.

Stage-1

Title Of the Project:-

Replace and modernize legacy VPN Architectures with a cloud-native Zscaler Zero trust solution to reduce attack surface and lateral movement.

Overview:-

This project focuses on modernizing traditional VPN architectures by replacing them with a cloud-native Zero Trust solution using Zscaler. In many organizations, legacy VPN systems are used to provide remote access to internal resources. However, these systems often allow users to access the entire network once they are authenticated, which increases the risk of cyber attacks and unauthorized access.

The Zero Trust model improves security by verifying every user and device before granting access to applications. Instead of giving full network access, users are allowed to connect only to the specific resources they are authorized to use.

By implementing the Zscaler cloud platform, organizations can ensure secure remote access, continuous monitoring, and strict access control. This approach reduces the chances of data breaches, prevents lateral movement within the network, and provides a more secure and scalable alternative to traditional VPN systems

s.no	Vulnerability name	CWE/CVE no
1	Absolute Path Travels	CWE 36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE-614
3	Use of Unmaintained Third Party Components	CWE-1104

Report:

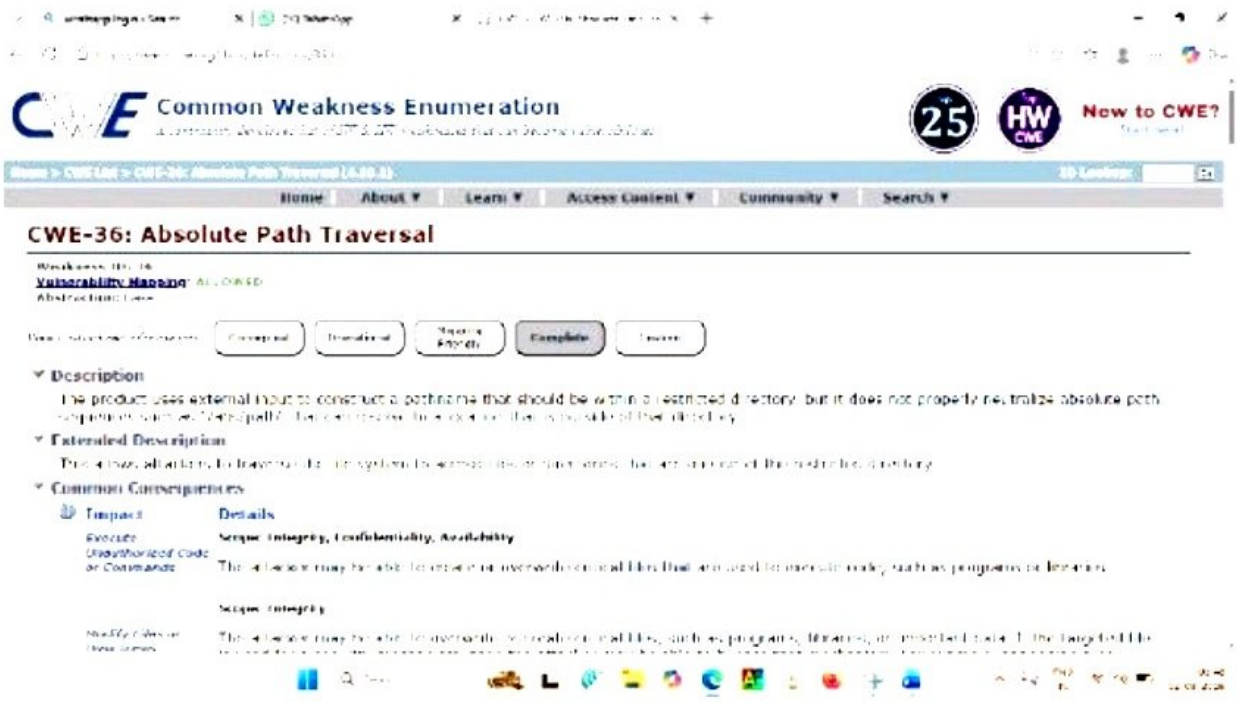
Vulnerability name :Absolute Path Traversal

Cwe/ cve number: CWE 36

Owasp category: A01:2025 Broken Access Control

Description: Absolute path Travels allows attackers to access restricted files or Directories by manipulating file paths due to improper input validation.

Business impact: Attackers may gain unautherized access to sensitive files, leading to data leakage and security risks.



Vulnerability Name: Absolute Path Traversal

CWE Number: CWE-36 Absolute Path Traversal

OWASP Category: OWASP A05:2021 Security Misconfiguration

Description:

Absolute Path Traversal vulnerability occurs when a web application uses user input to access files on the server without proper validation. Attackers can manipulate the file path by providing absolute paths to access files outside the allowed directory. This allows unauthorized users to view or access sensitive files stored in the system.

Business Impact:-

This vulnerability can expose sensitive information such as system configuration files, user data, or application source code. If attackers gain access to important files, it may lead to data leakage, system compromise, and loss of confidentiality. For organizations, this can cause financial loss, damage to reputation, and potential legal issues.

Stage 2

Title: Nessus scan

Overview:-

In this stage, the focus is on implementing and understanding how a cloud-native Zero Trust architecture using Zscaler can replace traditional VPN systems. Many organizations rely on legacy VPN architectures for remote connectivity, but these systems create security risks because they allow users to access the internal network once authentication is completed.

The Zero Trust approach improves security by ensuring that every user, device, and connection request is verified before access is granted. Instead of providing full network access, the system allows users to connect only to the specific applications they are authorized to use. This reduces the attack surface and protects sensitive organizational data.

During this stage, the architecture of the Zscaler platform and its role in secure access management is analyzed. Zscaler acts as a secure cloud gateway that connects users directly to applications without exposing the internal network. It continuously checks user identity, device status, and security policies before allowing any connection.

In this stage, vulnerability scanning is performed using Nessus. Nessus is a popular security scanning tool used to identify vulnerabilities in systems, networks, and applications. It helps detect security weaknesses such as outdated software, misconfigurations, and potential threats. By performing a Nessus scan, organizations can analyze their system security

and take necessary steps to fix the identified vulnerabilities and improve overall protection.

By implementing this approach, organizations can ensure secure remote access, prevent unauthorized access, and reduce the chances of lateral movement within the network. This stage demonstrates how adopting a Zero Trust model can significantly improve the overall

S.no	Vulnerability name	Severity	Plugins
1	Service detection	Info	22964
2	Port scanners	Info	39446
3	General	Info	11219
4	General	Info	46180
5	General	Info	45590
6	General	Info	54615
7	General	Info	19506
8	General	Info	209654
9	General	Info	11936
10	General	Info	209654

Report:-

Vulnerability Name:- Service Detection

Severity:- Info

Plugin:- 22964

Description:- This vulnerability indicates that the scanning tool has detected the running services on the target system. Service detection helps to identify which services and ports are active in the system. This information is useful for security analysis but does not indicate a direct security threat

Solution:- No immediate action is required since this is an informational finding. However, administrators should regularly monitor services and disable unnecessary services to reduce potential attack surfaces.

Business impact:- Since this is an informational level vulnerability, it does not directly affect business operations. However, exposed service information could help attackers understand the system environment if not properly managed

Stage3

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview:-

In this stage, the focus is on analyzing the benefits and effectiveness of implementing the Zscaler Zero Trust architecture in place of traditional VPN systems. After understanding the design and implementation of the cloud-native solution, this stage evaluates how the system improves security, access control, and network performance.

The Zero Trust model ensures that all users, devices, and connections are continuously verified before accessing applications. This reduces the possibility of unauthorized access and protects sensitive organizational data. Unlike legacy VPN architectures, the Zero Trust approach does not allow full network access, which helps prevent attackers from moving laterally across the network.

In this stage, the system's ability to provide secure remote access, enforce strict security policies, and monitor user activities is examined. The Zscaler platform also provides better visibility into network traffic and helps organizations

detect and respond to potential threats more effectively.

Overall, this stage highlights how the implementation of a cloud -native Zero Trust security model enhances network protection, reduces cyber security risks, and provides a modern alternative to traditional VPN-based architectures.

Identity:-

Identity plays an important role in the Zero Trust security model. In traditional VPN systems, users are usually authenticated only once, and after that they are given broad access to the internal network. This approach increases the risk of unauthorized access and security breaches.

In the Zscaler Zero Trust architecture, identity is used as the primary factor for granting access to applications and resources. Every user must verify their identity before accessing any system. The platform continuously checks the user's identity, device status, and security policies before allowing access.

By using strong identity verification methods such as user authentication, multi-factor authentication (MFA), and identity-based access control, the system ensures that only authorized users can access specific applications. This reduces the risk of cyber attacks and prevents unauthorized users from entering the network.

Overall, identity-based security helps organizations maintain better control over user access, protect sensitive data, and strengthen the overall security of the network.

Device posture:-

Device posture refers to the security condition or status of a device that is trying to access an application or network. In the

Zero Trust security model, it is important to ensure that the device being used is secure and compliant with the organization's security policies.

In the Zscaler Zero Trust architecture, the system checks the device posture before granting access to any application. This includes verifying whether the device has updated security patches, antivirus protection, and proper security configurations. If the device does not meet the required security standards, access may be restricted or denied.

By evaluating the device posture, organizations can prevent compromised or unsafe devices from accessing sensitive resources. This helps reduce security risks, protect important data, and maintain a secure network environment.

Overall, device posture verification strengthens the Zero Trust model by ensuring that only secure and trusted devices are allowed to access organizational applications and services.

Application risk:-

Application risk refers to the potential security threats that may arise from using different applications within an organization. Some applications may contain vulnerabilities or may not follow proper security standards, which can expose the system to cyber attacks and data breaches.

In the Zero Trust security model, every application is carefully evaluated before users are allowed to access it. The Zscaler platform helps identify and manage application risks by monitoring application behavior, controlling access

permissions, and enforcing security policies.

By analyzing application risk, organizations can ensure that users access only trusted and secure applications. Suspicious or high-risk applications can be restricted or blocked to protect sensitive information.

Overall, managing application risk helps improve security, reduce potential threats, and maintain a safe and reliable environment for accessing organizational resources

Context aware access:-

Context-aware access is an important concept in the Zero Trust security model. It means that access to applications and resources is granted based on different contextual factors such as user identity, device security status, location, and time of access.

In the Zscaler Zero Trust architecture, the system evaluates these factors before allowing a user to access any application. For example, if a user tries to access a system from an unknown location or from an unsecured device, the platform may restrict or deny access.

This approach ensures that security decisions are not based only on user authentication but also on the overall context of the access request. By analyzing multiple factors, the system

can identify potential risks and protect the network from unauthorized access.

Overall, context-aware access improves security by ensuring that only trusted users with secure devices and appropriate conditions are allowed to access organizational resources.

Conclusion

After understanding the importance of replacing legacy VPN architectures with a cloud-native Zscaler Zero Trust solution, it is necessary to follow certain steps to implement and ensure secure access. The following steps explain how the Zero Trust model verifies users, devices, and access conditions before granting permission to applications and resources.

Stage 1: Identity Verification

The first step in the Zero Trust security model is verifying the identity of the user who is requesting access to an application or resource. In traditional VPN systems, authentication usually happens only once, and after that the user is allowed to access the network. However, in the Zero Trust approach, identity verification plays a very important role.

The system checks the user's credentials such as username and password, and may also use advanced authentication methods like multi-factor authentication (MFA). This ensures that the person requesting access is a legitimate and authorized user. By strongly verifying user identity, organizations can prevent unauthorized individuals from accessing sensitive systems and data

Stage 2: Device Posture Verification

After verifying the user's identity, the next step is to check the security status of the device that the user is using to access the application. This process is known as device posture verification.

The system checks whether the device meets the organization's security requirements. This may include verifying if the device has updated operating systems, installed antivirus software, proper security patches, and secure configurations. If the device does not meet these requirements or is considered unsafe, the system may restrict or deny access.

This step ensures that only secure and trusted devices are allowed to connect to organizational resources, thereby reducing the risk of malware infections and cyber attacks.

Stage 3: Context-Aware Access Control

The third step involves evaluating the context of the access request before granting permission. In the Zero Trust model, security decisions are not based only on identity and device status but also on other contextual factors.

The system analyzes details such as the user's location, time of access, network conditions, and overall behavior. For example, if a user tries to access an application from an unusual location or an unknown network, the system may block or limit the access.

This context-aware access control ensures that every access request is carefully evaluated before permission is granted. By considering multiple factors, the Zero Trust system can identify potential security risks and provide better protection for organizational resources

In the future, Zscaler Zero Trust can be integrated with Artificial Intelligence (AI) and Machine Learning (ML) technologies. These technologies can automatically analyze network traffic and user behavior to detect unusual or suspicious activities. This will help organizations identify cyber threats quickly and take immediate action to prevent security breaches.

Stage 2: Extend Zero Trust Security to IoT Devices

As the use of Internet of Things (IoT) devices continues to grow, Zero Trust security can be extended to protect these devices. Smart devices, sensors, and other connected systems can be secured using the Zero Trust model. This will help organizations maintain strong security and prevent unauthorized access to connected devices.

Stage 3: Improve Real-Time Monitoring and Threat Response

Future improvements in Zscaler can focus on advanced real-time monitoring systems. These systems will continuously monitor network activities and detect threats instantly. With automated response mechanisms, security teams can quickly respond to cyber attacks and reduce the risk of data breaches.

Topics explored:

OWASP Top 10:

OWASP Top 10 is a list of the most common web application security risks. It helps developers and security professionals understand major vulnerabilities and how to prevent them.

Scanning:

Scanning is the process of checking a system or network to identify security weaknesses. It helps to find vulnerabilities that attackers might exploit.

Vulnerability:

A vulnerability is a weakness or flaw in a system, software, or network that can be exploited by attackers to gain unauthorized access or cause damage.

Awareness:

Security awareness means educating users and organizations about cyber threats and safe practices to prevent security attacks.

Identity:

Identity refers to verifying and managing the identity of users before allowing them to access systems or applications. It

ensures that only authorized users can access sensitive resources.

Tools explored:

Zscaler:

Zscaler is a cloud-based security platform that provides secure access to applications and protects users from cyber threats using the Zero Trust security model.

Nessus:

Nessus is a vulnerability scanning tool used to identify security issues in computers, networks, and applications.

OWASP:

OWASP is an open-source organization that provides tools, documentation, and resources to improve web application security.

Hack This Site:

Hack This Site is a legal hacking practice platform where users can learn and practice cybersecurity skills through different challenges.